

Information Technology Security Policy

Pawan Pvt Ltd — IT and Information Security

Version 3.1 | Effective 1 July 2025

Table of Contents

1. Purpose and Scope

This policy defines the minimum security requirements for the use of information systems at Pawan Pvt Ltd. It applies to all employees, contractors, interns, and third-party vendors who access company systems, data, or networks.

The policy covers company-issued devices, personal devices used for work, cloud services, and physical access to areas where information systems are housed.

Compliance is mandatory. Breach of this policy may result in withdrawal of access, disciplinary action, and where applicable, referral to law enforcement.

2. Account and Access Management

2.1 User Accounts

Every user is issued an individual account. Shared accounts are prohibited except for a small number of service accounts approved by the IT Security Manager and recorded in the service account register.

Accounts are created only on receipt of an approved access request from the hiring manager, submitted through the IT service desk.

2.2 Password Requirements

Passwords must be at least 14 characters and must not reuse any of the previous five passwords. Passwords must not contain the user's name, employee ID, or the company name.

Passwords expire every 180 days for standard accounts and every 90 days for privileged accounts.

Passwords must never be shared, written down in an unsecured location, or transmitted over email or chat. The company provides an approved password manager; users are expected to use it.

2.3 Multi-Factor Authentication

Multi-factor authentication (MFA) is mandatory for:

- Remote access through the corporate VPN.
- All cloud administrative consoles.
- Email and collaboration tools.
- Any system holding customer personal data.

Hardware security keys are issued to all users with privileged access. SMS-based one-time passwords are not accepted as a second factor for privileged accounts.

2.4 Privileged Access

Privileged access is granted on a least-privilege basis, for a defined period, with a documented business justification. Standing administrative access is not permitted for routine work.

Privileged access is reviewed quarterly by the IT Security Manager together with the relevant system owner. Access no longer required is revoked within five working days of the review.

2.5 Access Revocation

On the last working day of an employee, all access is revoked at close of business. Where an employee is terminated with immediate effect, access is revoked within one hour of notification from HR.

Contractor access is provisioned with an automatic expiry date matching the contract end date, and requires explicit renewal to continue.

3. Device Security

3.1 Company-Issued Devices

All company laptops are issued with full-disk encryption enabled, endpoint protection installed, and automatic security patching configured. Users must not disable these controls.

Devices must lock automatically after five minutes of inactivity. Users must lock their screen whenever leaving a device unattended, including within company premises.

3.2 Software Installation

Users may install software only from the approved software catalogue. Requests for software not in the catalogue are submitted to the IT service desk and are assessed for security, licensing, and support implications.

Installation of unlicensed software, cracked software, or software from untrusted sources is prohibited and is treated as serious misconduct.

3.3 Personal Devices

Personal devices may be used to access company email and calendar only, and only where the device is enrolled in mobile device management. Enrolment permits the company to enforce a device passcode, enforce encryption, and remotely wipe company data.

Personal devices must not be used to store company documents, access production systems, or connect to the corporate network.

3.4 Removable Media

USB storage devices are blocked by default on company laptops. Where a business need exists, an exception is granted for a specific device, encrypted, and registered with the IT service desk.

Transfer of company data to unregistered removable media is prohibited.

3.5 Loss or Theft

Loss or theft of any device holding company data must be reported to the IT service desk immediately, and in any case within four hours of discovery. Reports made outside working hours should use the 24-hour security line.

On report, the device is remotely wiped and the user's credentials are reset.

4. Network Security

4.1 Corporate Network

Access to the corporate network requires an authenticated, managed device. Unmanaged devices connect to the guest network only.

The guest network is segregated from the corporate network and provides internet access only.

4.2 Remote Access

Remote access to internal systems is permitted only through the corporate VPN with MFA. Split tunnelling is disabled; all traffic routes through the corporate gateway while the VPN is active.

Users must not connect to internal systems from public or shared computers, including hotel business centres and internet cafes.

4.3 Public Wi-Fi

Where a user must work from a public Wi-Fi network, the VPN must be active before any company system is accessed. Users should prefer a mobile hotspot from a company-issued device where one is available.

4.4 Firewall and Segmentation

Production, development, and corporate networks are segmented. Traffic between segments is denied by default and permitted only through documented, reviewed firewall rules.

Firewall rules are reviewed every six months. Rules with no matching traffic in the preceding 90 days are flagged for removal.

5. Data Classification and Handling

5.1 Classification Levels

All company information is classified into one of four levels:

- **Public** — information approved for external release, such as published product literature.
- **Internal** — information intended for employees, such as this policy. Disclosure would cause minor harm.
- **Confidential** — commercially sensitive information such as pricing models, contracts, and customer lists. Disclosure would cause significant harm.
- **Restricted** — personal data, financial records, and security credentials. Disclosure would cause severe harm and may create legal liability.

5.2 Handling Requirements

Confidential and Restricted information must be encrypted at rest and in transit. It may be shared externally only under a signed non-disclosure agreement and with the approval of the data owner.

Restricted information must not be copied to local device storage, sent over personal email, or shared through consumer file-sharing services.

5.3 Retention and Disposal

Data is retained in accordance with the Data Retention Schedule maintained by the Legal Department. Data that has reached the end of its retention period is deleted within 90 days.

Physical media holding Confidential or Restricted data is destroyed by an approved vendor, with a certificate of destruction retained by IT.

5.4 Personal Data

Personal data of employees, customers, and vendors is processed only for the purpose for which it was collected, and only by users with a business need.

Requests from individuals to access, correct, or delete their personal data are routed to the Data Protection Officer at dpo@pawanpvtltd.example and are responded to within 30 days.

6. Email and Communication

6.1 Acceptable Use

Company email is provided for business purposes. Incidental personal use is permitted where it is reasonable and does not breach this policy.

Users must not use company email to send content that is unlawful, harassing, or offensive, or to conduct a personal business.

6.2 Phishing

Users must not click links or open attachments in unexpected emails, even where the sender appears familiar. Suspected phishing is reported using the Report Phishing button in the email client.

The company runs simulated phishing exercises quarterly. Users who fail two consecutive simulations are enrolled in additional training.

6.3 External Sharing

Documents shared with external parties must use the approved file-sharing service with link expiry set to a maximum of 30 days. Public links without access restriction are prohibited for Confidential and Restricted data.

7. Incident Response

7.1 Reporting

Any suspected security incident must be reported immediately to the IT service desk or to security@pawanpvtltd.example. Examples include suspected malware, unauthorised access, accidental disclosure of data, and lost devices.

Users must not attempt to investigate or resolve an incident themselves. Preserving evidence is more important than restoring service quickly.

7.2 Response Process

The IT Security Manager triages every reported incident within two hours during working hours, and within four hours outside working hours.

Incidents are classified as Low, Medium, High, or Critical. High and Critical incidents trigger the formation of an incident response team including IT Security, Legal, and the affected business owner.

7.3 Notification

Where an incident involves personal data, the Data Protection Officer assesses notification obligations. Where notification is required, affected individuals and the relevant authority are notified within the statutory timeframe.

7.4 Post-Incident Review

Every High and Critical incident is followed by a post-incident review within 15 working days. The review documents the timeline, root cause, and corrective actions, with owners and target dates for each action.

8. Third-Party and Vendor Security

8.1 Assessment

Vendors with access to company systems or data complete a security assessment before contract signature. The assessment covers access controls, encryption, incident response, and sub-processor arrangements.

Vendors handling Restricted data must additionally provide evidence of an independent security certification.

8.2 Contractual Requirements

Vendor contracts include obligations covering confidentiality, breach notification within 24 hours, right to audit, and secure deletion of company data on termination.

8.3 Ongoing Review

Vendor security is reviewed annually, or immediately following a reported breach at the vendor. Vendors that fail review are placed on a remediation plan with a defined deadline, after which access may be withdrawn.

9. Training and Compliance

9.1 Security Awareness Training

All employees complete security awareness training within 15 days of joining and annually thereafter. Completion is tracked by HR and reported to the IT Security Manager.

9.2 Policy Acknowledgement

Employees acknowledge this policy on joining and on each material revision. Acknowledgement is recorded in the HR portal.

9.3 Audit

Compliance with this policy is audited annually by Internal Audit. Findings are reported to the Audit Committee, with agreed remediation tracked to closure.

9.4 Exceptions

Exceptions to this policy require written approval from the IT Security Manager, with a documented business justification, compensating controls, and an expiry date not exceeding 12 months. Exceptions are recorded in the exception register and reviewed quarterly.